

Système de Détection de Spam et Phishing basé sur l'IA

Rapport de Projet - Personne A
Analyse des Menaces et Ingénierie des IoC

Étudiant : Personne A
Encadré par Pr. Sara Ouald Chaib

6 mai 2026

Résumé

Ce document détaille la phase d'analyse des menaces et d'ingénierie des caractéristiques pour le système de détection de spam et phishing. L'approche est centrée sur la cybersécurité, transformant les vecteurs d'attaque en indicateurs de compromission (IoC) exploitables par des modèles d'apprentissage automatique.

Table des matières

1 Analyse des Menaces et Architecture de Défense

L'idée principale de ce projet n'est pas de concevoir un simple modèle de Machine Learning, mais bien de déployer une véritable architecture de détection orientée cybersécurité. Avant d'extraire la moindre donnée, j'ai décidé de structurer formellement les menaces auxquelles notre système doit faire face. M'appuyer sur la logique réelle des attaques m'a permis de concevoir un pipeline de défense beaucoup plus robuste face au comportement adaptatif des attaquants.

1.1 Classification des Vecteurs d'Attaque

J'ai séparé les menaces en deux grandes catégories en fonction de leurs cibles et de leurs impacts sur le triptyque de sécurité (Confidentialité, Intégrité, Disponibilité) :

- **Le Spam traditionnel (Nuisance et Disponibilité) :** C'est le bruit de fond d'Internet. L'objectif de l'attaquant est de diffuser un volume massif de messages. Le risque de compromission critique est faible, mais ce volume d'attaques sature la bande passante et fait perdre un temps précieux. L'impact se situe donc principalement au niveau de la *Disponibilité* du système d'information.
- **Le Phishing et Spear Phishing (Compromission et Ingénierie Sociale) :** C'est la véritable menace. L'attaquant cible directement la *Confidentialité* et l'*Intégrité* du réseau. Le vecteur d'attaque est l'email, mais l'arme principale est psychologique : c'est l'ingénierie sociale. L'objectif est de manipuler la victime pour réaliser un vol d'identifiants (credential theft) ou la forcer à exécuter une charge utile malveillante (payload, comme un dropper). Dans le cas du Spear Phishing, le message est ultra-ciblé. Sans filtre adapté, un seul clic peut compromettre toute l'infrastructure.

1.2 Comportement Adaptatif et Résilience Offensive

Les attaquants savent très bien comment fonctionnent les filtres basés sur des signatures statiques. Ils modifient constamment leurs campagnes pour bypasser ces défenses : utilisation de caractères invisibles (obfuscation), génération de domaines aléatoires, usurpation d'identité (spoofing). Pour contrer cette évolution, on est parti sur l'extraction d'Indicateurs de Compromission (IoC) comportementaux et structurels. Le but est de détecter l'intention malveillante et les anomalies d'infrastructure, plutôt que de se fier à un vocabulaire figé.

2 Architecture de Filtrage Multi-Couches et IoCs

Pour fournir à notre système de détection des données pertinentes, j'ai conçu le processus d'ingénierie des caractéristiques comme un firewall applicatif. Chaque email traverse un filtrage multi-couches, où chaque caractéristique agit comme un Indicateur de Compromission (IoC) spécifique.

2.1 Classification des Indicateurs de Compromission (IoCs)

J'ai structuré l'extraction de nos IoCs en cinq couches défensives :

1. **Header & Authentication IoCs (Anomalies de routage et Spoofing)**
 - *Reply-To Mismatch* : Différence entre l'adresse d'expédition et l'adresse de réponse.
 - *Défaut d'alignement SPF/DKIM/DMARC* : Indicateurs critiques de l'usurpation d'identité.
2. **URL & Domain IoCs (Vecteurs de redirection malveillante)**
 - *IP-based URLs* : Utilisation d'adresses IP nues pour contourner les listes noires DNS.
 - *TLDs suspects* : Forte présence de domaines génériques jetables (.xyz, .top, .click).
 - *Homoglyphes et Entropie* : Détection de domaines similaires à des marques connues (ex : paypal.com) ou générés aléatoirement (DGA).
3. **Behavioral & Psychological IoCs (Marqueurs d'ingénierie sociale)**
 - *Densité d'urgence* : Fréquence des mots imposant un délai très court ("immédiatement", "suspendu").
 - *Requêtes de Credentials* : Présence de vocabulaire ciblant l'authentification ("login", "vérifier compte").
4. **Content & Obfuscation IoCs (Contournement de filtres)**
 - *Ratio HTML/Texte et Majuscules* : Les emails malveillants présentent souvent un formatage aberrant.
 - *Obfuscation Unicode et Leetspeak* : Insertion de caractères de largeur nulle (zero-width) pour tromper les filtres lexicaux.
5. **Metadata IoCs (Vecteurs de Payload)**
 - *Extensions à risque* : Présence de pièces jointes agissant comme "droppers" (.exe, .vbs, .scr, .js).

2.2 Mapping Attaque → Défense

Pour s'assurer que notre modèle repose sur une vraie logique de sécurité, j'ai dressé un mapping direct entre la technique de l'attaquant et l'IoC utilisé pour le bloquer. Ça m'a évité pas mal de biais de détection au final.

Au final, cette architecture en couches garantit que même si l'attaquant modifie le texte de son email (bypass du *Content IoC*), il a de fortes chances d'être détecté par les anomalies de routage (*Header IoC*) ou par l'analyse comportementale (*Behavioral IoC*).

Comportement de l'Attaquant	Vecteur d'Attaque	IoC Défensif Associé
Contournement DNS par masquage du domaine	Redirection vers serveur malveillant via IP	<i>IP-based URL Count</i> (> 0)
Usurpation d'un cadre dirigeant (CEO Fraud)	Email Spoofing	<i>Reply-To Mismatch</i> et <i>SPF/DKIM Failures</i>
Bypass des filtres lexicaux	Obfuscation (Leetspeak, caractères invisibles)	<i>Zero-width chars</i> et <i>Leetspeak anomalies</i>
Manipulation pour forcer une action	Ingénierie Sociale (Pression psychologique)	<i>Densité du vocabulaire d'urgence</i>
Livraison de malware	Attachement piégé	<i>Suspicious Attachment Extension</i> (.vbs, .scr)

TABLE 1 – Mapping des techniques d'attaques vers nos Indicateurs de Compromission (IoCs)